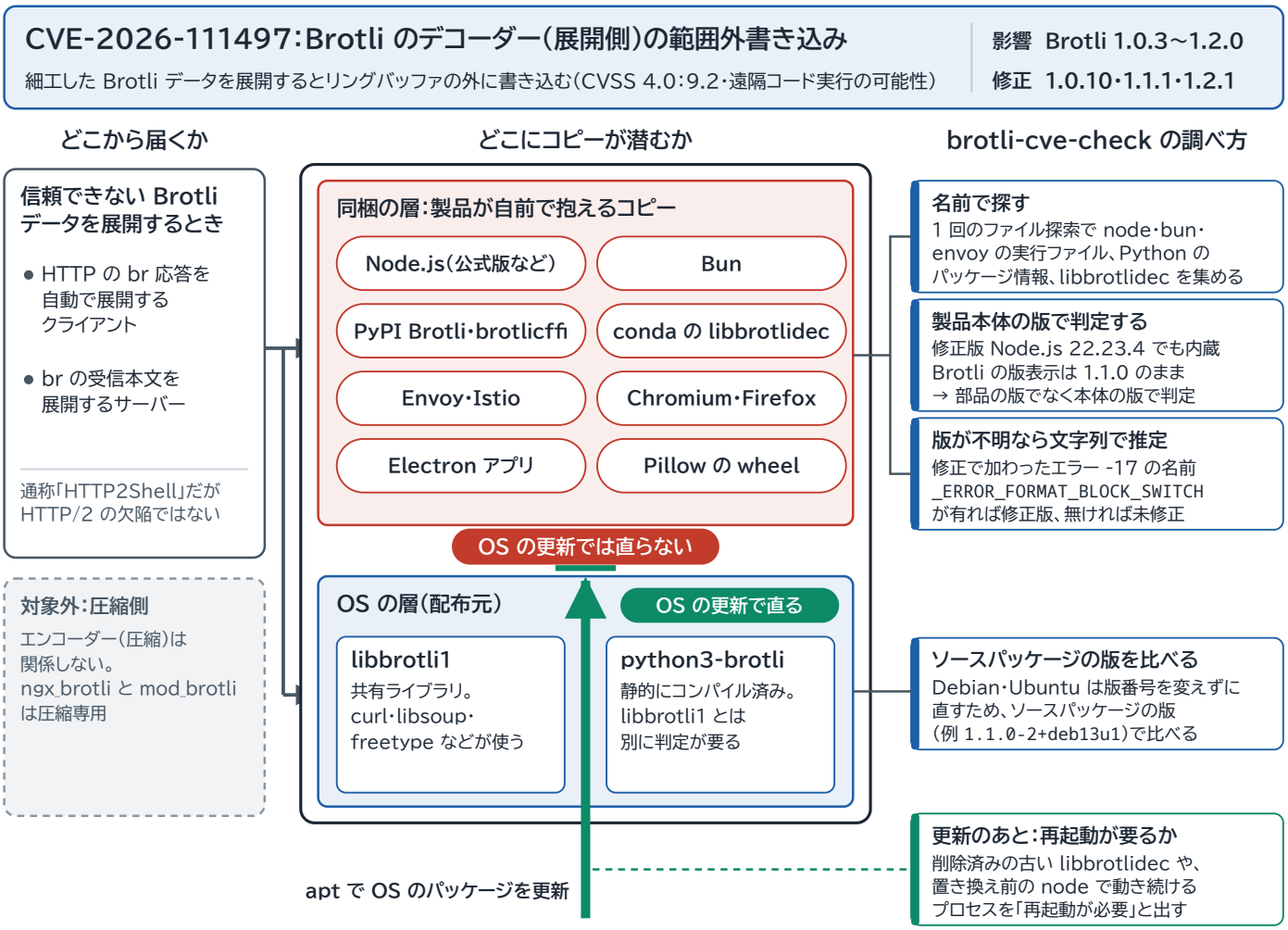
図解 01　何を、どのようにチェックしたか　CVE-2026-111497



この1枚の読み方

1. **弱点は展開側（デコーダー）にあり、信頼できない Brotli データを展開するときに届く。**HTTP の `Content-Encoding: br` の応答を自動展開するクライアントや、br の受信本文を展開するサーバーが経路になる。上流は 2026-10-21 に 1.0.10・1.1.1・1.2.1 で修正した（GHSA-9v8h-qqgm-4m35）。
2. **同梱コピーは製品ごとの更新が要る（OS の更新では直らない）。**修正版の例: Node.js 22.23.4・24.22.1・26.12.1、Bun 1.4.4、PyPI の Brotli 1.2.1。文字列による推定は Brotli 1.2.0／1.2.1 の自前ビルド、Node.js 公式バイナリ、PyPI の wheel で確かめ、エラー名の表が削られたビルドは判定せず `VENDORED_COPY`（要確認）と出す。2026-10-26 時点で Ubuntu の OS パッケージは修正版が未提供（Debian 12・13 は修正済み）。
3. **読み取り専用で、「安全」とは表示しない。**書き込むのは標準出力と `--output` だけで、ネットワークも攻撃データも使わない。見つけたプログラムは `--version` を尋ねるときだけ、環境変数を空・制限時間つき・他人が置き換えられない場所のものに限って実行する。urllib3・requests・httpx・aiohttp が同じ環境にあれば、応答を自動展開する手がかりとして示す（脆弱性そのものではない）。走査しなかった範囲を必ず並べ、侵入の有無は調べない。

OS の更新が直すのは OS のコピーだけで、同梱コピーは版と文字列で一つずつ洗い出す。

処方箋　SHA256 を確かめてから `sudo bash brotli-cve-check --lang ja` を読み取り専用で走らせ、「更新が必要なもの」「再起動が必要なもの」に挙がったものから更新・再起動する。

出典: GHSA-9v8h-qqgm-4m35・PYSEC-2026-4322・brotli-cve-check v0.1.0 の docs